Foram implementadas as 4 validações, seguindo a lógica de:

OBS: Nenhuma senha foi criptografada, foi tudo feito em formato hardcoded pra poder realizar os testes, porém em um cenário real deveira ser implementada também esse tipo de validação e proteção

Bloqueio Temporário de Contas: Após 3 tentativas falhas consecutivas, bloquear o login do usuário por 5 minutos.

Foi utilizado um hashmap, para realizar contagens de tentativas de login, para que pudesse ser verificado se o usuário X atingiu o limite de tentativas, se sim, ocorre o bloqueio, caso contrário permite fazer login.

O sistema automaticamente faz a limpa da contagem depois de um login bem sucedido.

Atraso Progressivo: Aumentar o tempo de resposta a cada tentativa falha (exemplo: 2s, 4s, 8s...).

Todas as requisições de falha, possuem um delay que aumenta * 2 a cada requisição falha, caso consiga se autenticar o delay é removido, utilizei um hashmap para armazenar o valor de tempo do delay para cada usuário que tenta realizar o login.

Registro de Tentativas por IP: Restringir múltiplas tentativas vindas do mesmo endereço IP.

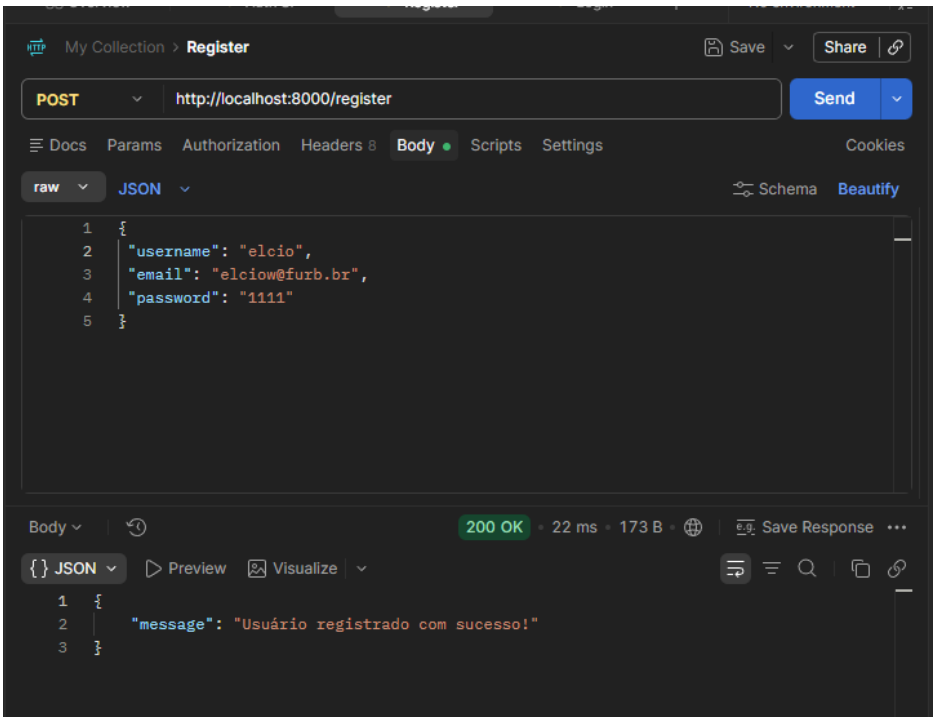
A cada requisição o sistema conta o número de chamadas vindas de um determinado IP, não necessitando ser de um único usuário, caso o número seja maior que 5 requisições, então faz o bloqueio de requisições vindas daquele endereço de IP, caso contrario permite mais tentativas, nessa implementação o endereço vai ser bloqueado permanentemente até que a aplicação seja executada novamente, porém se ouver necessidade basta adicionar um reset no contador para poder realizar novas requisições via aquele IP.

Autenticação de Dois Fatores (2FA): Após o login, exigir um código enviado por e-mail.

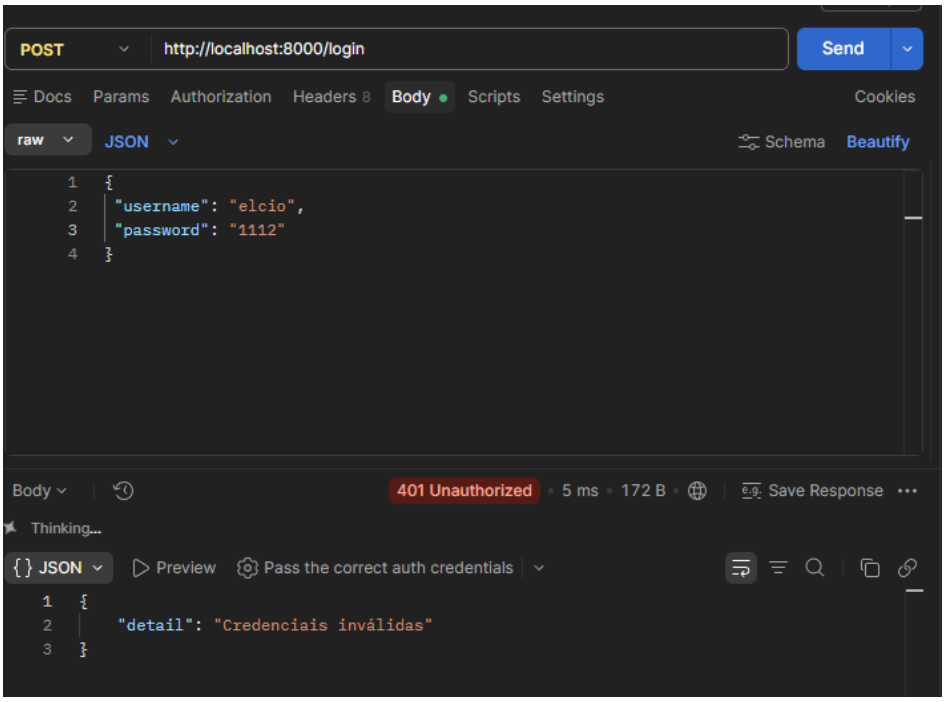
Para a validação de 2 fatores, utilizei a biblioteca SMTP, que utilizando um código de aplicativo do gmail permite enviar emais personalizados para qualquer email desejado, assim possibilita o envio de um código para o solicitante, para que seja validado no endpoint de validação criado, assim permite o login, caso contrário so barra a autenticação, além disso, o código permite ser enviado 5 vezes, caso contrário, cancela a requisição e ocorre falha no login (também utiliza um hashmap contador).

Prints do funcionamento:

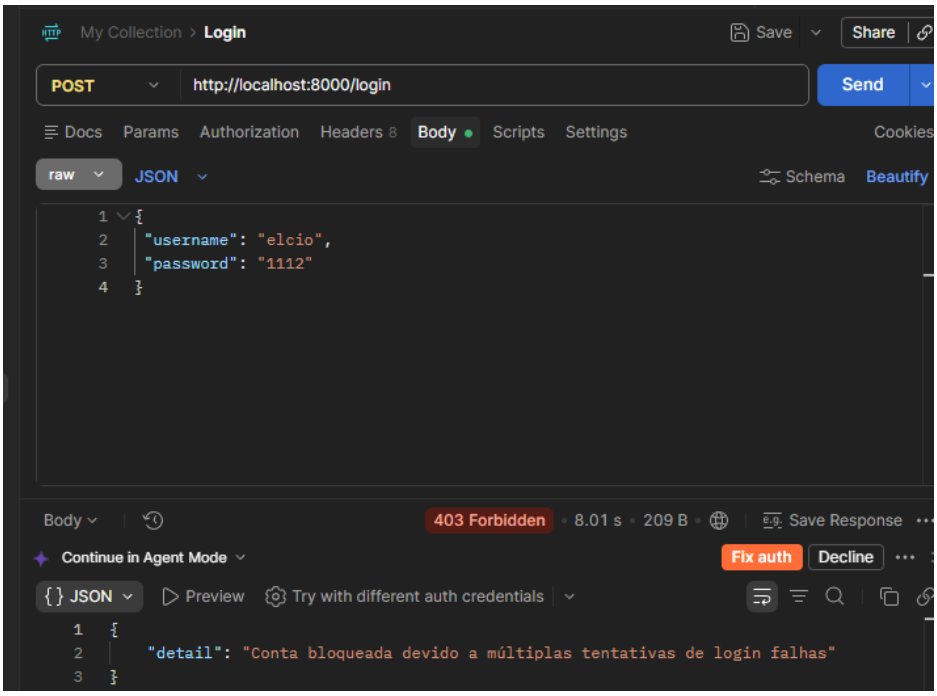
Registrando um usuário:

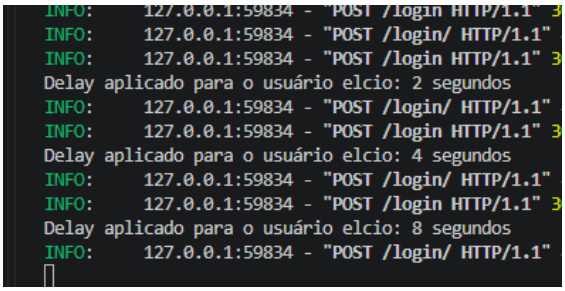


Executando tentativas de login falha:

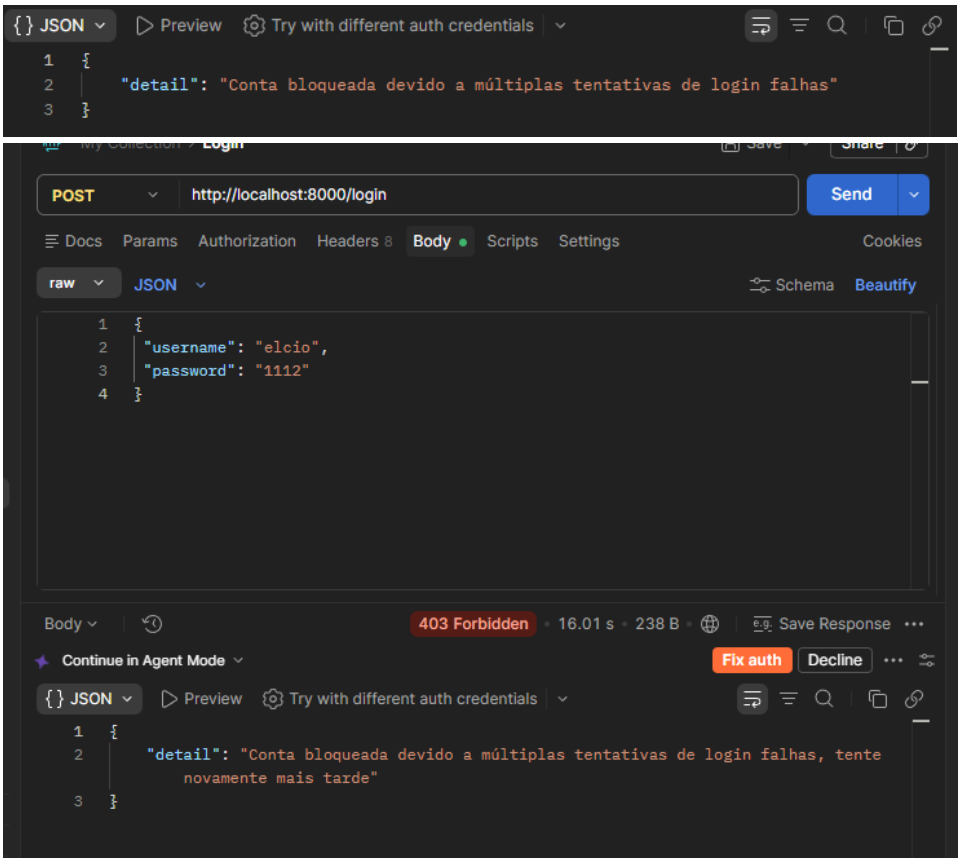


Cada requisição tem um crescimento de tempo, no console é printado uma mensagem guia:

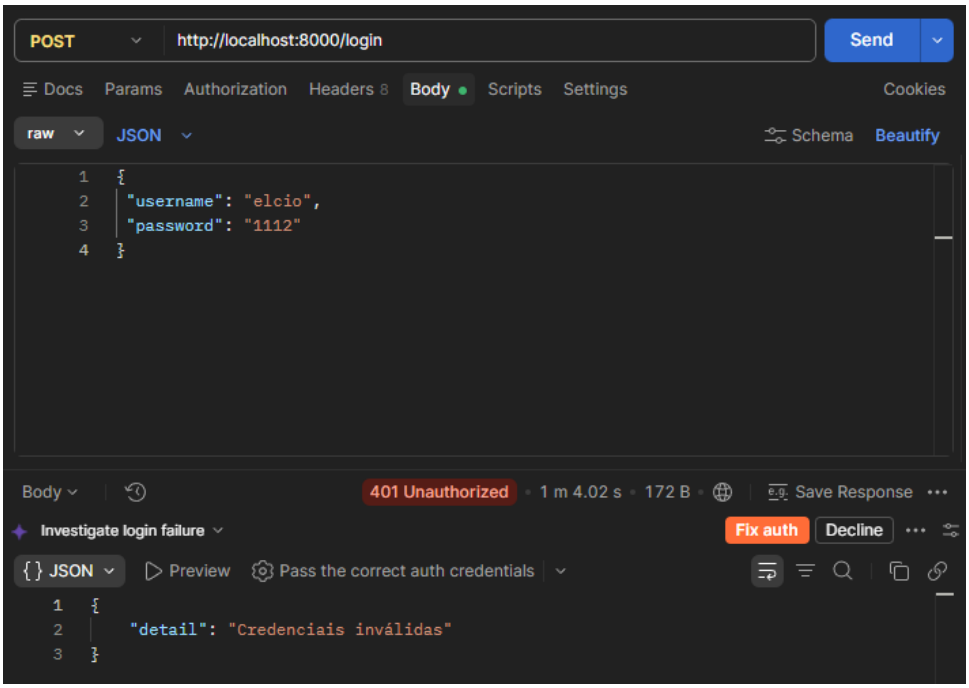




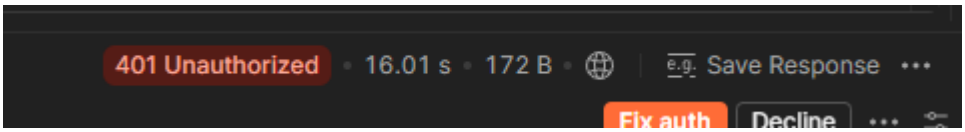
Excesso de tentativas também bloqueia a conta, após enviar 3 requisições falhas, bloqueia o login do usuário, se insistir antes do tempo e atingir 6 request, tem o IP bloqueado:



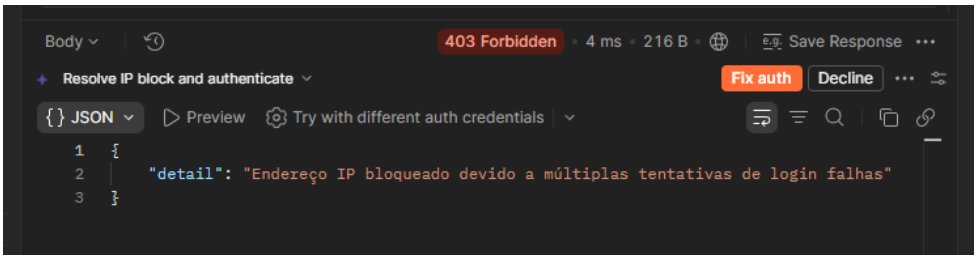
Após o tempo passar, permite novas requisições:

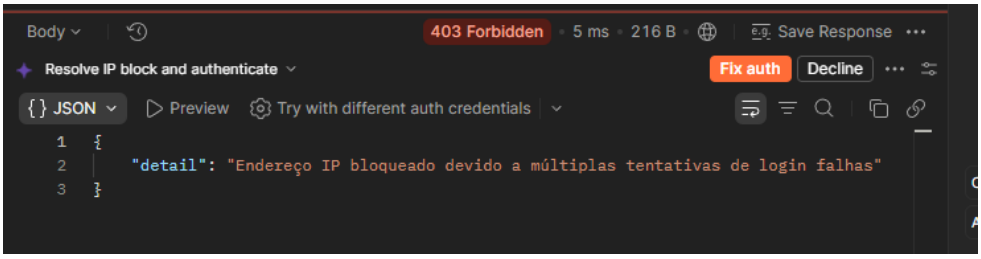


O tempo da requisição continua aumentado mesmo bloqueado:

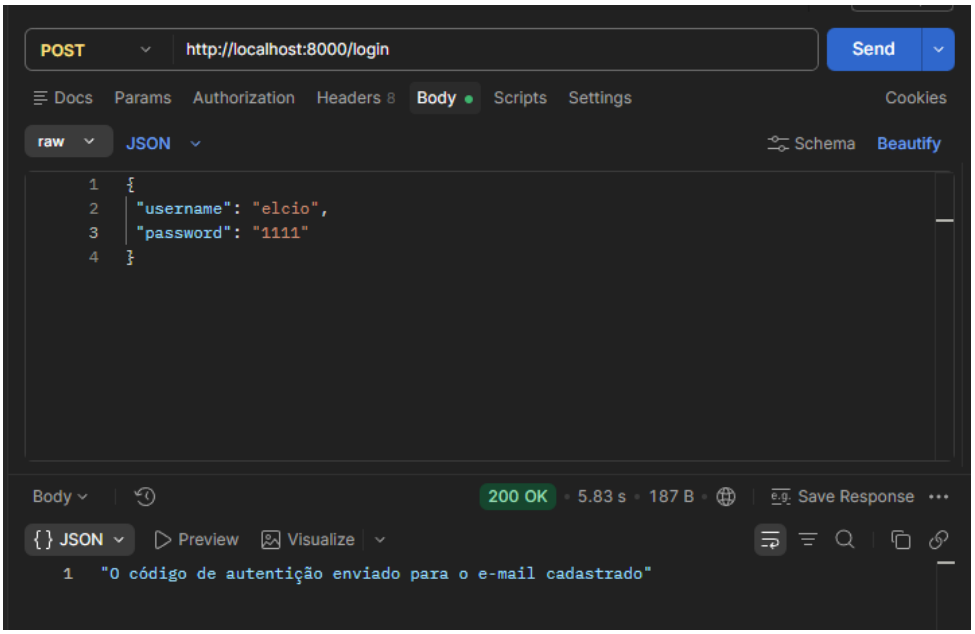


Após 6 ou mais tentativas, o endereço de IP é bloqueado:

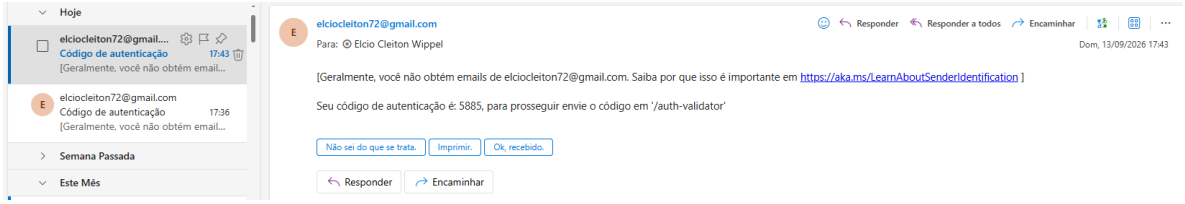




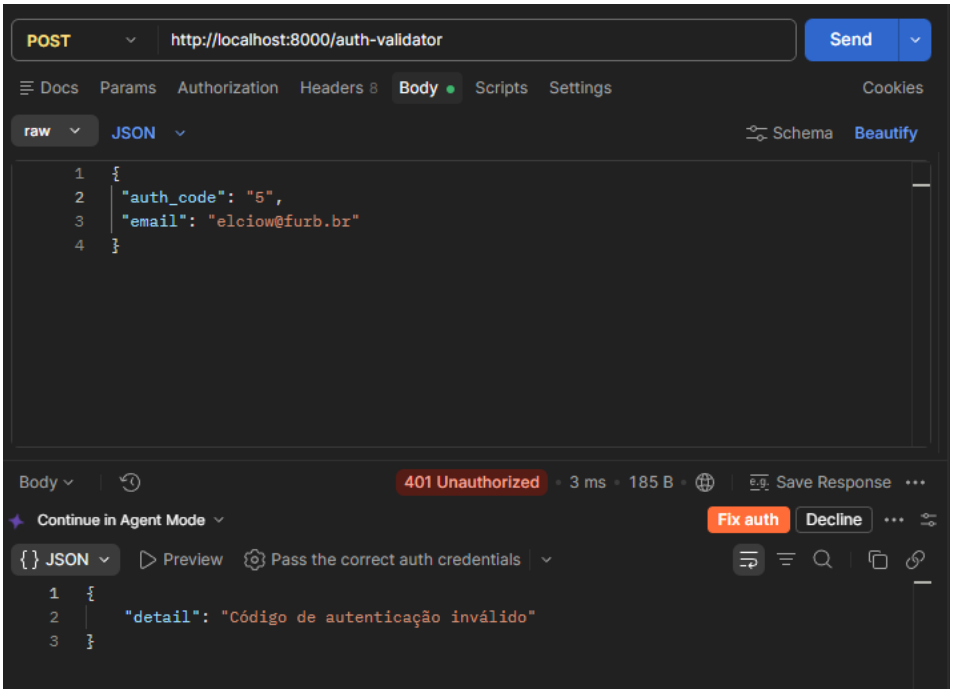
Código de 2 fatores enviado para o email:



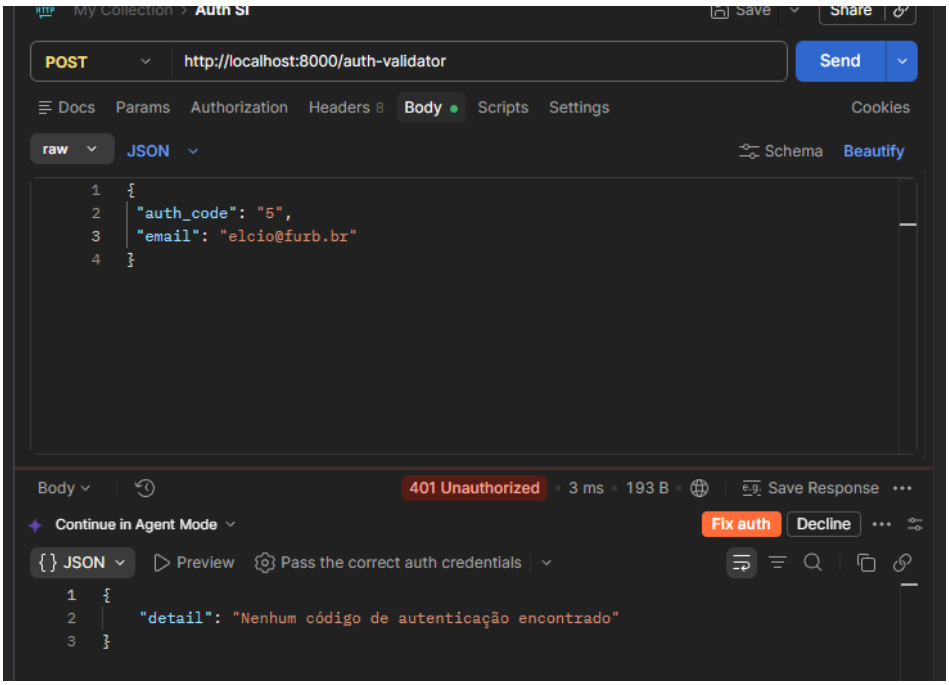
Código recebido no e-mail cadastrado:



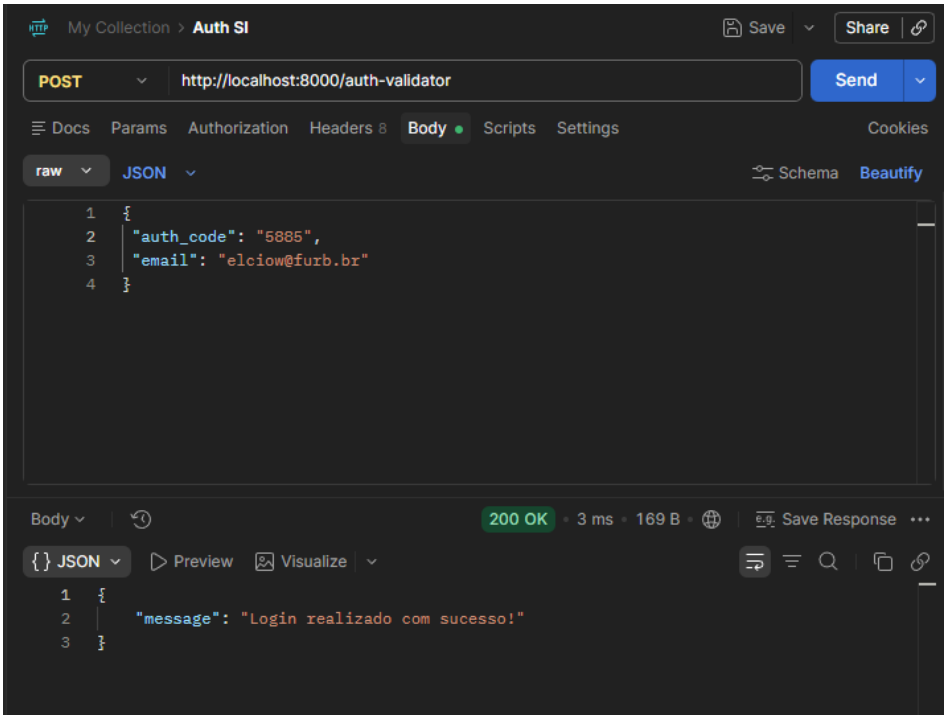
Código inválido:



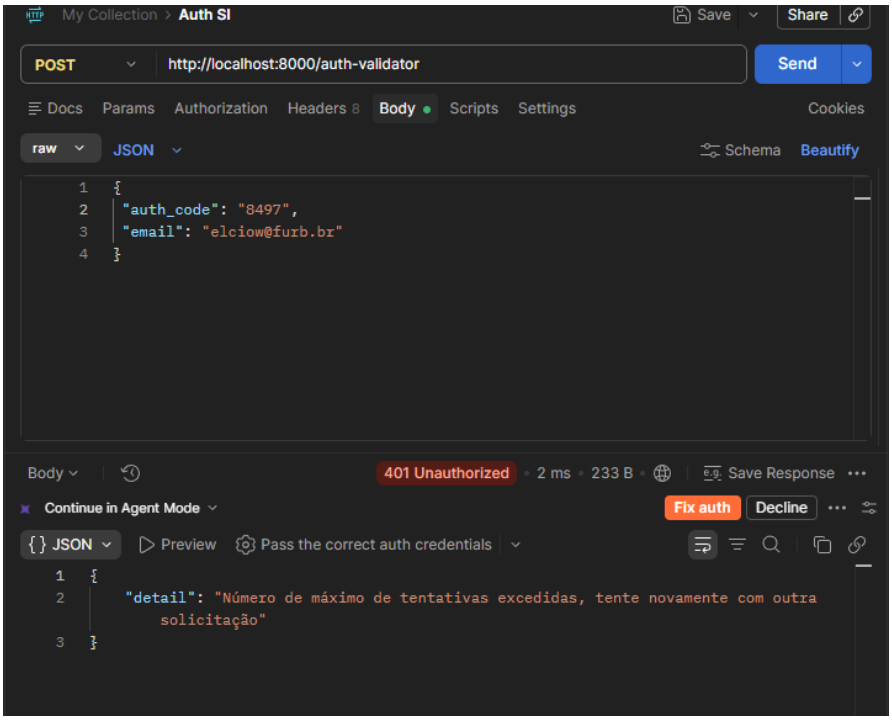
Não existe código em aguardo:



Requisição para aprovar o código com sucesso:



Error após mais de 5 tentativas incorretas:



Após nova solicitação, redefine a contagem:

